ASSIGNMENT 5.1

Agent Authentication and Host Integrity Verification

Student	[Student Name]	Roll No	[Roll No]
Course	21CSE525T - Agent Technology	Project	Placement Preparation Agent

Unit 5 - Six sequential verification gates for incoming commands. File: assignments/a5_1/secure_agent.py

1. Objective

Accept commands only from authenticated, authorised and fresh messages, and block every tampering or impersonation attempt.

2. Trusted registry

Three registered hosts: placement-cell-01 (ADMIN), mentor-node-07 (TRAINER) and student-agent-a (PEER). Each has a shared secret and a registered IP address.

Roles limit what a host may do: ADMIN may run UPDATE_PLAN, PUSH_DRIVE, WIPE_PROFILE and SYNC_STATE; TRAINER may run UPDATE_PLAN and SYNC_STATE; PEER may run only SYNC_STATE.

3. The six gates

- **GATE-1 Structure:** all required fields (host_id, command, args, nonce, timestamp, signature) must be present.
- **GATE-2 Registry:** the host_id must be a registered host.
- **GATE-3 Origin:** the source IP must match the registered address for that host.
- **GATE-4 Signature:** HMAC-SHA256 over the canonical payload, compared in constant time with hmac.compare_digest.
- **GATE-5 Freshness:** the timestamp must be within 30 seconds, and the nonce must not have been used before.
- **GATE-6 Authorisation:** the host's role must allow the requested command.

4. Implementation

```
class SecureAgentGateway:
    def __init__(self, ip_allowlist=("127.0.0.1",)):
        self.allow = set(ip_allowlist)
        self.accepted = 0
        self.rejected = 0
        self.audit = []

    def _reject(self, gate, reason):
        self.rejected += 1
        self.audit.append(("REJECT", gate, reason))
        log("SECURITY", f"  X GATE-{gate} FAILED -&gt; {reason}")
        raise SecurityException(f"[GATE-{gate}] {reason}")

    def verify(self, msg, src_ip="127.0.0.1"):
        body = msg.get("body", {})
        sig = msg.get("signature", "")
        hid = body.get("host_id")

        # ---- GATE 1 : structural integrity ---------------------------
        for f in ("host_id", "command", "args", "nonce", "timestamp"):
            if f not in body:
                self._reject(1, f"malformed payload, missing field '{f}'")
        log("SECURITY", "  OK GATE-1 payload structure valid")

        # ---- GATE 2 : host identity is known -------------------------
        if hid not in TRUSTED_HOSTS:
            self._reject(2, f"unknown host_id '{hid}' -- not in trusted registry")
        host = TRUSTED_HOSTS[hid]
        log("SECURITY", f"  OK GATE-2 host '{hid}' found in trusted registry (role={host['role']})")
```

```
        # ---- GATE 3 : host integrity / origin IP ---------------------
        if src_ip not in self.allow or src_ip != host["ip"]:
            self._reject(3, f"host integrity violation: '{hid}' claimed from {src_ip}, "
                            f"registered {host['ip']}")
        log("SECURITY", f"  OK GATE-3 origin IP {src_ip} matches registered host")

        # ---- GATE 4 : cryptographic signature ------------------------
        expected = hmac.new(host["secret"], canonical(body), hashlib.sha256).hexdigest()
        if not hmac.compare_digest(expected, sig):     # constant-time
            self._reject(4, f"HMAC-SHA256 signature mismatch "
                            f"(expected {expected[:16]}..., got {sig[:16] or 'EMPTY'}...)")
        log("SECURITY", f"  OK GATE-4 signature verified {sig[:16]}...")

        # ---- GATE 5 : replay / freshness -----------------------------
        age = int(time.time()) - body["timestamp"]
        if abs(age) &gt; REPLAY_WINDOW_SEC:
            self._reject(5, f"stale message: age {age}s exceeds {REPLAY_WINDOW_SEC}s window")
        if body["nonce"] in SEEN_NONCES:
            self._reject(5, f"REPLAY ATTACK: nonce {body['nonce']} already consumed")
        SEEN_NONCES.add(body["nonce"])
        log("SECURITY", f"  OK GATE-5 freshness ok (age={age}s), nonce unique")

        # ---- GATE 6 : authorization (role -&gt; command) ---------------
        allowed = ROLE_PERMISSIONS[host["role"]]
        if body["command"] not in allowed:
            self._reject(6, f"PRIVILEGE ESCALATION: role '{host['role']}' may not "
                            f"execute '{body['command']}' (allowed: {sorted(allowed)})")
        log("SECURITY", f"  OK GATE-6 role '{host['role']}' authorized for '{body['command']}'")

        self.accepted += 1
        self.audit.append(("ACCEPT", 0, f"{hid}:{body['command']}"))
        return body

    # ---------------- protected agent action ---------------------------
    def execute(self, msg, src_ip="127.0.0.1"):
        try:
            body = self.verify(msg, src_ip)
            log("AGENT", f"  &gt;&gt; EXECUTING '{body['command']}' args={body['args']}")
            return True
        except SecurityException as e:
            log("AGENT", f"  &gt;&gt; COMMAND BLOCKED. Agent state unchanged. {e}")
            return False
```

5. Result

Two legitimate commands from the ADMIN and TRAINER hosts pass all six gates. Eight attacks are blocked: forged signature (GATE-4), unknown host (GATE-2), tampered payload (GATE-4), replay (GATE-5), privilege escalation by a PEER (GATE-6), IP spoofing (GATE-3), stale message (GATE-5) and malformed payload (GATE-1). Each block leaves the agent's state unchanged and is written to the audit log.

Execution output (log file)

Captured from **logs/5.1_secure_agent.log** (python3 secure_agent.py). Timestamps and some values differ between runs; this is the recorded run.

```
# Activity 5.1_secure_agent
# command: python3 secure_agent.py
# exit code: 0


================================================================================
 AGENT AUTHENTICATION &amp;amp; HOST INTEGRITY VERIFICATION (Assignment 5.1)
================================================================================
 Trusted hosts     : ['placement-cell-01', 'mentor-node-07', 'student-agent-a']
 Signature scheme  : HMAC-SHA256 over canonical JSON
 Replay window     : 30s + single-use nonce
 Verification gates: 6 (structure, identity, origin, signature, freshness, authz)

--- SCENARIO 1: LEGITIMATE command from trusted ADMIN host ------------------
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   OK GATE-2 host 'placement-cell-01' found in trusted registry (role=ADMIN)
[12:26:33] [SECURITY    ]   OK GATE-3 origin IP 127.0.0.1 matches registered host
[12:26:33] [SECURITY    ]   OK GATE-4 signature verified ab6ab48d1b8fcf00...
[12:26:33] [SECURITY    ]   OK GATE-5 freshness ok (age=0s), nonce unique
[12:26:33] [SECURITY    ]   OK GATE-6 role 'ADMIN' authorized for 'PUSH_DRIVE'
[12:26:33] [AGENT       ]   &gt;&gt; EXECUTING 'PUSH_DRIVE' args={'company': 'Amazon', 'date': '2026-09-15'}
```

```
--- SCENARIO 2: LEGITIMATE command from TRAINER host ------------------------
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   OK GATE-2 host 'mentor-node-07' found in trusted registry (role=TRAINER)
[12:26:33] [SECURITY    ]   OK GATE-3 origin IP 127.0.0.1 matches registered host
[12:26:33] [SECURITY    ]   OK GATE-4 signature verified 56cfdc41bf9e8fbe...
[12:26:33] [SECURITY    ]   OK GATE-5 freshness ok (age=0s), nonce unique
[12:26:33] [SECURITY    ]   OK GATE-6 role 'TRAINER' authorized for 'UPDATE_PLAN'
[12:26:33] [AGENT       ]   &gt;&gt; EXECUTING 'UPDATE_PLAN' args={'add_topic': 'Graphs'}

--- SCENARIO 3: ATTACK - forged signature (attacker guesses the key) --------
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   OK GATE-2 host 'placement-cell-01' found in trusted registry (role=ADMIN)
[12:26:33] [SECURITY    ]   OK GATE-3 origin IP 127.0.0.1 matches registered host
[12:26:33] [SECURITY    ]   X GATE-4 FAILED -&gt; HMAC-SHA256 signature mismatch (expected 2b64f57416a86c0c..., got 9508f27
[12:26:33] [AGENT       ]   &gt;&gt; COMMAND BLOCKED. Agent state unchanged. [GATE-4] HMAC-SHA256 signature mismatch (expec

--- SCENARIO 4: ATTACK - unknown/unregistered rogue host --------------------
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   X GATE-2 FAILED -&gt; unknown host_id 'evil-node-99' -- not in trusted registry
[12:26:33] [AGENT       ]   &gt;&gt; COMMAND BLOCKED. Agent state unchanged. [GATE-2] unknown host_id 'evil-node-99' -- not

--- SCENARIO 5: ATTACK - tampered payload (man-in-the-middle mutation) ------
[12:26:33] [ATTACKER    ]   intercepted message and injected 'delete_all_progress': True
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   OK GATE-2 host 'mentor-node-07' found in trusted registry (role=TRAINER)
[12:26:33] [SECURITY    ]   OK GATE-3 origin IP 127.0.0.1 matches registered host
[12:26:33] [SECURITY    ]   X GATE-4 FAILED -&gt; HMAC-SHA256 signature mismatch (expected fd83ecce5e81ed67..., got de034a4
[12:26:33] [AGENT       ]   &gt;&gt; COMMAND BLOCKED. Agent state unchanged. [GATE-4] HMAC-SHA256 signature mismatch (expec

--- SCENARIO 6: ATTACK - replay of a previously valid message ---------------
[12:26:33] [ATTACKER    ]   re-sending the captured Scenario-1 packet verbatim
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   OK GATE-2 host 'placement-cell-01' found in trusted registry (role=ADMIN)
[12:26:33] [SECURITY    ]   OK GATE-3 origin IP 127.0.0.1 matches registered host
[12:26:33] [SECURITY    ]   OK GATE-4 signature verified ab6ab48d1b8fcf00...
[12:26:33] [SECURITY    ]   X GATE-5 FAILED -&gt; REPLAY ATTACK: nonce 0f83c6e2e521db6f already consumed
[12:26:33] [AGENT       ]   &gt;&gt; COMMAND BLOCKED. Agent state unchanged. [GATE-5] REPLAY ATTACK: nonce 0f83c6e2e521db6f

--- SCENARIO 7: ATTACK - privilege escalation by a low-privilege PEER -------
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   OK GATE-2 host 'student-agent-a' found in trusted registry (role=PEER)
[12:26:33] [SECURITY    ]   OK GATE-3 origin IP 127.0.0.1 matches registered host
[12:26:33] [SECURITY    ]   OK GATE-4 signature verified 4e0b81f1a9699f2d...
[12:26:33] [SECURITY    ]   OK GATE-5 freshness ok (age=0s), nonce unique
[12:26:33] [SECURITY    ]   X GATE-6 FAILED -&gt; PRIVILEGE ESCALATION: role 'PEER' may not execute 'WIPE_PROFILE' (allowed
[12:26:33] [AGENT       ]   &gt;&gt; COMMAND BLOCKED. Agent state unchanged. [GATE-6] PRIVILEGE ESCALATION: role 'PEER' may

--- SCENARIO 8: ATTACK - host spoofing from a non-registered IP -------------
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   OK GATE-2 host 'placement-cell-01' found in trusted registry (role=ADMIN)
[12:26:33] [SECURITY    ]   X GATE-3 FAILED -&gt; host integrity violation: 'placement-cell-01' claimed from 203.0.113.66,
[12:26:33] [AGENT       ]   &gt;&gt; COMMAND BLOCKED. Agent state unchanged. [GATE-3] host integrity violation: 'placement-

--- SCENARIO 9: ATTACK - stale/expired message (clock rollback) -------------
[12:26:33] [SECURITY    ]   OK GATE-1 payload structure valid
[12:26:33] [SECURITY    ]   OK GATE-2 host 'placement-cell-01' found in trusted registry (role=ADMIN)
[12:26:33] [SECURITY    ]   OK GATE-3 origin IP 127.0.0.1 matches registered host
[12:26:33] [SECURITY    ]   OK GATE-4 signature verified 01a30b986fbfcaf1...

... (middle of run omitted; full log in logs/5.1_secure_agent.log) ...

 REJECT   GATE-4 HMAC-SHA256 signature mismatch (expected 2b64f57416a86c0c..., got 9508f2722a52d004...)
 REJECT   GATE-2 unknown host_id 'evil-node-99' -- not in trusted registry
 REJECT   GATE-4 HMAC-SHA256 signature mismatch (expected fd83ecce5e81ed67..., got de034a4e4cfda18e...)
 REJECT   GATE-5 REPLAY ATTACK: nonce 0f83c6e2e521db6f already consumed
 REJECT   GATE-6 PRIVILEGE ESCALATION: role 'PEER' may not execute 'WIPE_PROFILE' (allowed: ['SYNC_STATE'])
 REJECT   GATE-3 host integrity violation: 'placement-cell-01' claimed from 203.0.113.66, registered 127.0.0.1
 REJECT   GATE-5 stale message: age 9999s exceeds 30s window
 REJECT   GATE-1 malformed payload, missing field 'host_id'
--------------------------------------------------------------------------------
 ACCEPTED : 2   REJECTED : 8   BLOCK RATE : 80.0%
 RESULT   : all unauthorized commands blocked; agent state never mutated.
================================================================================
```

6. Viva points

Why constant-time comparison? A normal string comparison stops at the first differing byte, which leaks timing information that could be used to guess a signature byte by byte.

Why a nonce as well as a timestamp? The timestamp limits how old a message can be; the nonce stops a replay within that window.

The attacks are simulated in one program so the results are reproducible.

7. Conclusion

Authentication, integrity, freshness and authorisation are checked in order, and each failure is reported at the gate where it happened.